Automotive Cyber Security Academy 2023

Basic Information Technology Security

Topic 3: Security Services, mechanisms and design principles

Automotive Cyber Security Academy

1 2 9 0 FACULDADE DE CIÊNCIAS E TECNOLOGIA UNIVERSIDADE D COIMBRA

dei departamento de engenharia informática

25/04/23

Outline

- Security Services
- Security Mechanisms and Protocols
- Design Principles

Note:

- Please recap the topic 2

Security Services

Security Services - Authentication

- Aims to assure that a communication is authentic
  - It assures to the recipient that the message is from the source it claims to be
  - In a ongoing interaction assures two entities are authentic and that the connection is not interfered.
- ITU X.800 classifies two types of authentication services:
  - Peer entity authentication – confirm the identities in an association. Entities use the same protocol for communicating (TCP/IP)
  - Data origin authentication– provides corroboration of the source of a data unit, assuring that the information information comes from a specific entity.

Security Services - Authentication

- Authentication approaches
  - Password-based authentication
  - Two-factor/Multifactor authentication
  - Biometric Authentication
  - Single Sign On (SSO) – used in Web context
  - Token-based authentication – Example of One Time Passwords (OTP)
  - Certificate based authentication – Using digital certificates

Security Services – Access Control

- Provides the ability to limit and control the access to systems and application in the communication links
- Requires the identification of identities (authentication) so that access rights can be tailored to specific entities.
- Examples:
  - Attribute Based Access Control (ABAC)
  - Role Based Access Control (RBAC)

Security Services – Data Confidentiality

- Protect transmitted data from passive attacks:
  - Protect all the user data transmitted between two users
  - Protect a single message or specific fields in a message
- Protect the traffic flow from analysis:
  - Protect characteristics of the traffic such as source, destination, frequency, length and others

Security Services – Data Integrity

- Can be applied to a stream of messages, single message of selected fields in a message
- Connection-oriented integrity service to assure that messages are not received without duplication, modification, reordering or replays.
- A connections-less integrity service deals with individual messages, protecting them against modifications only.

Security Services – Non Repudiation

- (remembering) prevents an entity to deny a specific action
- Requires other services, authentication, accounting, auditing and logging
- Supported with digital signatures

Security Services – Availability

- protect a system to ensure its availability
- Addresses issues related with security concerns in Denial-of-Service Attacks
- Relies also on the control of system resources and depends on the security services

Security Mechanisms and Protocols

Authentication Mechanisms and Protocols

- Lightweight Directory Access Protocol (LDAP) used to verify credentials in a directory service
- Challenge-Handshake Authentication Protocol (CHAP) uses challenge/response to authenticate instead of using secrets
- Extensible Authentication Protocol (EAP) uses in Wireless networks to support multiple authentication
- Kerberos authenticates users in a insecure network, without passwords but requires a trusted party
- OpenID Connect identity management on top of the OAuth 2.0 authorization framework, used in Web sites
- Security Assertion Markup Language (SAML) solution for SSO using XML and identity providers
- FIDO2 for web authentication via public key cryptography
- TLS public key cryptography and digital certificates to authenticate clients and servers

Access Control Approaches

- Discretionary Access Control (DAC) when providing file permissions
- Role based Access Control (RBAC) control managed per role/group
- Mandatory Access Control (MAC) for classified information military, government
- Rules Based Access Control (RAC) implemented in the application
- Firewall solutions

Source InfoSec

Non Repudiation Approaches

- Authenticating messages through Hash Message Authentication Code (HMAC)
  - Only for authentication and integrity of messages
- Digital Signatures (support for non repudiation):
  - Rely on Public-key encryption
  - Trusted Third Parties (TTP)

Availability Approaches

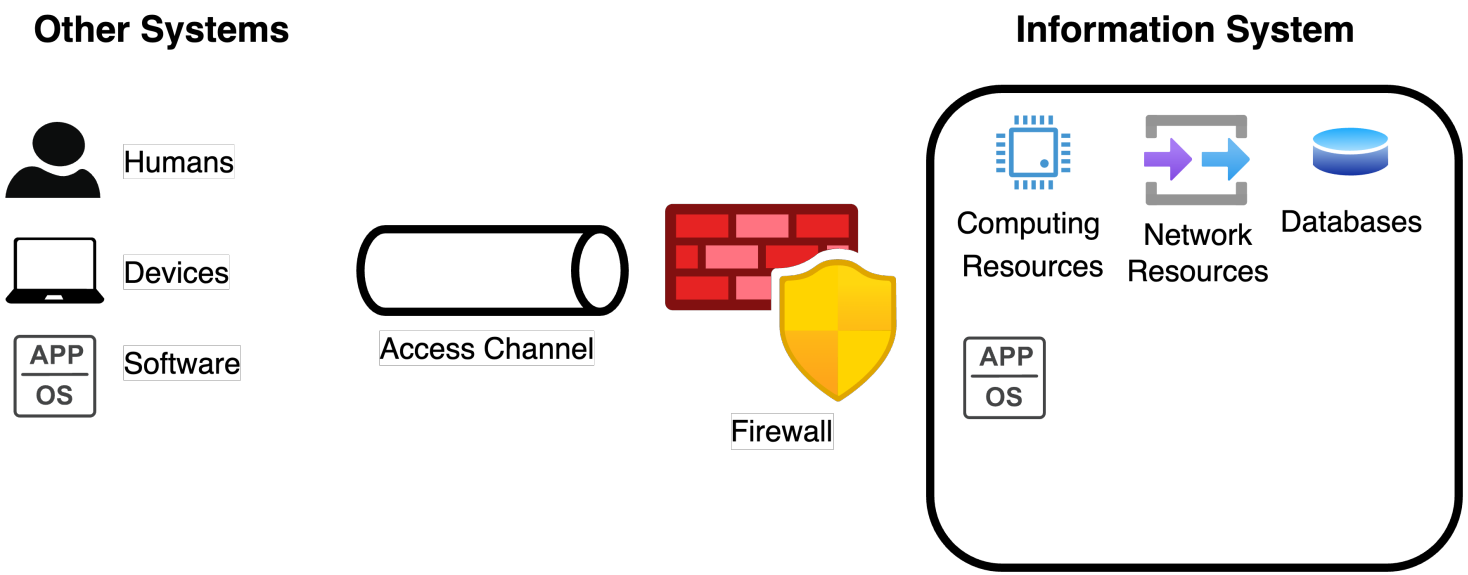
- Monitoring techniques
- Load Balancing services
- Using Service Mesh in microservices to enhance resilience of services
- Using Intrusion Detection and Prevention Systems (IDPS)
- Using Advanced techniques like Moving Target Defence (MTD)

Attack Surface

Attack Surface

- Defines the reachable and exploitable vulnerabilities in a system, attack vectors that can exist in a system
  - Open ports on facing web servers, Operating Systems (OSes) implementing web service
  - Services available in a firewall (VPN access), related OS, physical equipment
  - Software, code processing data
  - Interfaces with other services (SQL)

Network Access security model



- Components like a firewall help to implement access control mechanisms at network and service level

Design Principles

Design Principles for Security

- Security by Design in an approach that includes security and privacy concerns from the early phases of development:
- Security by Design considers some principles:
  - Expect attacks and care should be taken to minimize the impact
  - Avoid security through obscurity
  - Fewest Privileges, use applications in isolated environments
  - Continuous Delivery/continuous Integration (CI/CD)
  - Changing environments, new regulations that appear like GDPR

Security by Design Frameworks

- NIST SP 800-160 – guidelines to build trustworthy and secure systems. Specifications for architecture, design, development
- AWS Security by Design Framework – Mainly for AWS workloads
- Sherwoord Applied Business Security Architecture (SABSA) – business-driven enterprise security architecture framework
- Control Objectives for Information and Related Technologies (COBIT) – principles for business, alignment and processes optimization

Reflection

Reflections

- Which security principle is more relevant for you ?
- The security attacks discussed previously, which security service they affect ?

Thanks

Automotive Cyber Security Academy

The NEW and IMPROVED - ACSA 2023 is here!